



Artificial Intelligence (AI) Usage Policy

Purpose and Scope

This Artificial Intelligence (AI) Usage Policy ("Policy") establishes the requirements and guidelines for the responsible deployment of AI systems at **[Bank Name]**, a Massachusetts community bank with assets under \$1 billion. The Policy's goal is to ensure that all AI use cases – whether customer-facing (e.g. chatbots, credit underwriting models, fraud detection systems) or internal (e.g. transaction monitoring, compliance automation tools, human resources screening algorithms) – are identified, assessed, and governed in a manner that is safe, ethical, and compliant with applicable laws and regulations. It is the intent of the Board of Directors that this Policy be formally adopted as part of the bank's enterprise risk management framework, to proactively harness AI's benefits while protecting the bank and its customers from legal, regulatory, operational, and reputational risks ¹ ². The Policy applies to all officers, employees, and departments of the bank, and to any third-party or vendor engagements involving AI solutions on the bank's behalf.

Definitions

For purposes of this Policy, **Artificial Intelligence (AI)** is defined as *"a machine-based system that can, for a given set of human-defined objectives, make predictions, recommendations, or decisions influencing real or virtual environments"* ³. This definition encompasses a broad range of algorithmic and automated decision systems, including machine learning models and other complex predictive analytics. An **AI System** refers to any software, model, or process (including hardware or cloud service) operating in whole or in part using AI. A **Model** is further defined consistent with regulatory guidance as any quantitative method or algorithm that processes input data to generate an output (e.g. a score, decision, or recommendation); this includes statistical, financial, or mathematical models, including those that utilize AI or machine learning techniques ⁴. *Customer-facing AI* means any AI system that interacts with or makes decisions impacting consumers (such as chatbots or credit decision engines), while *Back-office AI* refers to internal operational uses (such as fraud detection, anti-money laundering analytics, compliance monitoring, or HR screening tools). **Bias** or **algorithmic bias** refers to error or deviation that produces unfair, inequitable, or discriminatory outcomes for certain groups of people. **Model risk** refers to the potential for adverse consequences from decisions based on incorrect or misused models ⁵. All other relevant terms (e.g. "personal information," "consumer report," etc.) shall carry the meaning defined by applicable law or regulation (see Appendix A).

AI Use Cases and Applications

The bank recognizes that AI can drive efficiency and innovation across a variety of use cases, but each application must be carefully vetted for risk. **Foreseeable AI use cases** in scope of this Policy include, but are not limited to:

- **Customer Service Chatbots and Virtual Assistants:** AI-powered chat interfaces or voice assistants that interact with customers for banking inquiries, product information, or basic transactions. These

systems can enhance customer experience and provide 24/7 support, but carry risks of providing incorrect information, lacking transparency that they are not human, or failing to accommodate customers with disabilities. Such tools must be monitored to prevent misleading or unfair practices

6 .

- **Credit Underwriting and Scoring Models:** Algorithms (including machine learning credit scoring models) used to evaluate loan applications, set credit limits, or price products. These AI models can improve consistency and potentially expand credit access, but they pose significant fair lending risk if they inadvertently discriminate or lack explainability for adverse action reasons 7 8 . All AI-driven credit decision systems are subject to rigorous fair lending review and compliance with the Equal Credit Opportunity Act (ECOA) and Mass. Gen. Laws ch.151B.
- **Fraud Detection and Transaction Monitoring:** AI systems that analyze transactions, customer behavior, or network activity to detect fraud, cyber threats, or suspicious activities (including AML/BSA transaction monitoring). These can improve threat detection but may generate false positives/negatives or exhibit bias. They must be tuned and validated to meet Bank Secrecy Act requirements and not unfairly block legitimate customer activity. Use of AI does **not** reduce the bank's obligation to maintain effective BSA/AML controls.
- **Regulatory Compliance Automation:** AI tools to automate compliance tasks (e.g. monitoring for consumer law violations, analyzing marketing materials, or scanning transactions for sanctions screening). These promise efficiency but must be thoroughly tested so that they do not overlook regulatory red flags. Compliance AI tools remain subject to all applicable laws (e.g. Fair Housing Act, Truth in Lending, UDAP standards) as if those tasks were performed manually – “there is no ‘AI exemption’ to the laws on the books” 2 .
- **Human Resources and Hiring Systems:** AI applications for recruiting, resume screening, employee performance analytics, or other HR decisions. These carry risks of employment discrimination (e.g. disparate impact against protected classes under Title VII or M.G.L. c.151B) or violations of the Americans with Disabilities Act. The bank must ensure such tools do not unfairly screen out candidates with disabilities or other protected characteristics; even unintentional bias can lead to unlawful discrimination 9 10 . Any AI used in employment decisions must be vetted by HR and Legal for compliance with anti-discrimination laws and provide accommodations as required 10 .
- **Additional Use Cases:** Other potential AI uses include portfolio management algorithms, automated real estate valuation models for appraisals, marketing analytics for personalized offers, and customer behavior analytics. Each such use will be evaluated on a case-by-case basis under this Policy. Notably, any automated valuation model (AVM) used for real estate lending must meet quality control standards and **comply with applicable nondiscrimination laws** 11 per the federal AVM rule. The breadth of use cases underscores that AI now impacts virtually all aspects of banking, and thus a comprehensive governance approach is required 6 .

Identification and Pre-Implementation Assessment of AI Systems

Identification of AI Systems: All business units must inventory and report any planned use of AI or algorithmic systems in their processes. Before any new AI system is implemented (including pilot programs or vendor-provided AI tools), the proposing unit shall notify the **AI Risk Review Committee** (or designated

management committee) for evaluation. This includes external vendor solutions and internally developed models. A **New AI Initiative Form** or similar documentation should be completed, capturing the system's purpose, how it works (at a high level), what data it uses, and the anticipated benefits and risks.

Pre-Implementation Risk Assessment: Every identified AI application must undergo a thorough risk assessment **prior** to approval and deployment. The assessment shall evaluate, at minimum: (1) **Compliance Risk** – which laws and regulations apply (see Appendix A) and how the AI will comply; (2) **Fair Lending and Ethics Risk** – analyze potential for bias or disparate impact on protected classes, and whether the model's design/inputs could result in unfair or unintended outcomes; (3) **Data Privacy and Security** – what personal data is used, and assurance that data handling meets privacy laws (e.g. GLBA, M.G.L. c.93H) and security standards (201 CMR 17.00) ¹²; (4) **Model Risk** – the complexity, transparency, and interpretability of the AI, including whether the model is a “black box” and how its outputs can be validated and explained ¹³ ⁸; (5) **Operational Risk** – reliability, scalability, and the risk of errors or downtime; (6) **Third-Party Risk** – if a vendor or third-party model is used, the risks related to that provider's reliability and compliance (see Vendor Management section below).

The AI Risk Review Committee will use a standardized **AI Risk Assessment Checklist** (see Appendix B for a sample) to ensure consistency. High-risk AI proposals (e.g. those impacting customer credit decisions, or those with high regulatory or ethical risk) must be reviewed by Compliance, Legal, the Chief Risk Officer (CRO), and other second-line oversight functions before approval. In some cases, consultation with regulators may be warranted prior to deployment of novel AI uses, consistent with regulatory expectations of transparency in significant new initiatives ¹⁴ ¹⁵. The bank will take a cautious, incremental approach: new AI applications should, where feasible, be trialed in a controlled pilot program or sandbox environment, with outcomes evaluated, before full rollout ¹⁶ ¹⁷. This phased approach allows the bank to “find a proof-of-concept, adopt it, get an early win...incremental” rather than a big-bang deployment ¹⁵ ¹⁷, thereby managing risk.

No AI system may be launched in production without formal written approval from the AI Risk Review Committee and the relevant executive (e.g. business line head in partnership with the CRO or CTO). The approving authority must document that risks have been considered and are deemed acceptable with appropriate controls in place. All approved AI systems shall be logged in the bank's **Model Inventory**, with unique identifiers, description of use, owner, and risk tier.

Governance, Oversight, and Model Risk Management

Board and Executive Oversight: Ultimate accountability for AI risk management rests with the Board of Directors and senior management. The Board (or a designated Board committee, such as the Risk Committee) shall approve this AI Usage Policy and review management's reports on AI activities at least annually. The Board expects management to cultivate a culture of compliance and risk awareness in AI use, consistent with the bank's values and all legal duties ¹⁸ ¹⁹. As regulators have emphasized, “there is no AI exemption” to existing laws ² – the bank's leadership is responsible for ensuring AI is used safely and lawfully. The Board delegates day-to-day oversight to executive management, including the **Chief Risk Officer (CRO)** and an **AI Oversight Committee** consisting of senior stakeholders from Risk, Compliance, Legal, IT, Information Security, Business Lines, and Audit. This committee will meet regularly to review AI use cases, monitor performance and issues, and enforce this Policy's requirements.

Policies and Procedures: The bank shall maintain detailed internal procedures for AI model development, validation, and monitoring. These procedures align with the bank's broader Model Risk Management (MRM) policy and regulatory guidance on model risk (e.g. OCC Bulletin 2011-12 and Federal Reserve SR 11-7) ²⁰

⁵ . Every AI model is subject to the same rigor as other models used by the bank. Key elements include:

- **Model Development & Documentation:** AI models (whether built in-house or by vendors) must be developed using sound design principles and documented thoroughly. Documentation shall cover the model's intended purpose, methodology (including training data and algorithms used), assumptions and limitations, and known or potential sources of error or bias. Developers must ensure the AI model meets a legitimate business need and consider less complex alternatives if available, especially if the AI's decision process will be opaque.
- **Independent Validation:** Consistent with supervisory expectations, the bank will perform **independent model validation** on AI systems prior to and periodically after deployment ⁵ . Validation shall be conducted by qualified personnel not involved in developing or using the model (e.g. a Model Risk Management team or an external validator), to provide an objective review. Validation will include evaluating conceptual soundness (is the model logically and statistically appropriate for its intended use?), testing outcomes against benchmark or hold-out data, and assessing robustness and sensitivity. Crucially for AI, validation will also assess **fairness and bias** – e.g. testing the model outputs for disparate impact or other discrimination, and reviewing variable importance to check for proxy discrimination. If the AI is a third-party product, the bank will obtain sufficient documentation from the vendor to facilitate effective validation; the vendor may be required to provide model code, developmental evidence, or results of its own bias and accuracy testing. Models that cannot be examined or explained (so-called “black box” models) pose heightened risk; the bank will generally **avoid deploying opaque AI models in core decision processes** unless accompanied by tools or techniques to interpret and explain the model's decisions ¹³ . The bank will follow emerging best practices for “interpretable AI,” such as using explainability techniques or simpler surrogate models, to satisfy regulatory expectations that decisions – especially adverse credit decisions – can be explained specifically to consumers ¹³ ²¹ .
- **Change Control:** Any material changes to an AI model (e.g. retraining with new data, altering features, model logic updates, or switching model vendor) must go through the model change-control process, including re-validation or at least targeted testing of the change. Likewise, if an AI system is repurposed for a new use or applied to a new customer segment, it should be treated as a new model for review purposes. Model owners must notify the AI Oversight Committee of any changes.
- **Ongoing Monitoring:** All AI systems in production require continuous monitoring and periodic review. The system owners, in coordination with Risk Management, shall track key performance indicators (KPIs) and key risk indicators (KRIs) for each AI tool. This includes accuracy rates, error rates, incidents or exceptions, customer complaints, model drift indicators, and any signs of disparate impact emerging over time. For instance, data drift or a change in population could degrade an AI model's performance or fairness; thus, metrics will be tracked to trigger alerts if the model's predictions start deviating or if outputs correlate unusually with protected classes. The bank's data governance function (led by a Chief Data Officer or similar) will ensure data quality is maintained, since poor data can “make the output of bad data seem reasonable,” potentially amplifying problems ²² ²³ . If monitoring detects issues (e.g. unexplained denial rate changes for a

minority group, or a spike in false positives in fraud detection), the bank will investigate and may suspend the AI system until remediated.

- **Governance and Controls:** The AI Oversight Committee will maintain a **Model Inventory** that identifies all AI/ML models in use. Each model will have an assigned *Model Owner* (business accountable person) and *Model Risk Tier*. Higher-risk models (for example, an AI credit underwriting model or an AML transaction monitoring system) will receive more frequent and stringent review (at least annual validation) compared to low-risk models (e.g. a simple internal workflow automation). The committee will also enforce **Controls** such as access restrictions (who can modify or use the model), version control, and outcome review processes. Where appropriate, “human-in-the-loop” controls will be implemented – meaning certain AI decisions will require human review or approval, particularly in early stages of deployment or for exceptional cases. For example, a loan denial recommendation from an AI model might be reviewed by a credit officer to ensure consistency and fairness, until sufficient confidence in the model is established.
- **Audit and Documentation:** Comprehensive documentation and audit trails must be maintained for all AI systems. This includes records of approvals, validation reports, training data sets and methodology, test results, and decisions made by the AI. Internal Audit (as the third line of defense) will periodically audit compliance with this Policy and the effectiveness of AI controls. Examiners and auditors should be able to review how a model was developed and how it’s governed. The bank acknowledges regulatory guidance that emphasizes sound model governance, policies, and controls as essential to managing model risk ⁵ ²⁴ . Audit findings and any material control gaps will be reported to the Board Audit/Risk Committee.

Regulatory Compliance Requirements

All uses of AI at the bank must **comply fully with applicable federal and state laws and regulations**. AI is not a loophole to evade legal obligations – as regulators have stated unequivocally, advancing technology does not absolve the bank from its responsibility to obey “laws on the books” in areas of consumer protection, fair lending, privacy, etc. ² . This section outlines key compliance areas and requirements:

1. Fair Lending and Anti-Discrimination

Equal Credit Opportunity Act (ECOA) and Regulation B: Any AI used in credit underwriting, pricing, marketing, or other credit decisions must comply with ECOA (15 U.S.C. §1691 et seq.) and its implementing Reg. B, which prohibit discrimination on the basis of race, color, religion, national origin, sex, marital status, age, receipt of public assistance, or exercise of consumer rights. The bank will ensure that AI-driven credit models are designed and tested to avoid disparate treatment *and* disparate impact on prohibited bases. This includes conducting fair lending statistical analyses (e.g. disparate impact testing) on model outputs and taking corrective action (model adjustments or variable exclusions) if disparities are found that lack a legitimate business necessity or less discriminatory alternative. In line with CFPB guidance (2023), the bank must also be able to explain *specific* reasons for any adverse action taken based on AI models ⁷ ²¹ . Simply citing a complex algorithm or using a generic reason code from a checklist is not sufficient – the reasons given to consumers must “specifically and accurately” indicate the principal factors for denial or other adverse action ⁸ ⁷ . For example, if an AI model reduces a credit line based on certain spending behaviors, the adverse action notice should detail the specific behavior (e.g. “high recent cash advances relative to balance”) rather than a vague category like “purchasing history” ²⁵ . The CFPB has made clear

that “there is no special exemption for artificial intelligence” when it comes to these requirements ²¹ – creditors cannot hide behind black-box models to justify non-compliance. The bank will therefore use tools (such as algorithmic explainers) to derive understandable reason codes from AI decisions ¹³, and will not employ AI models in credit decisions unless we can generate compliant adverse action explanations.

Fair Housing Act (FHA): The bank also adheres to the FHA (42 U.S.C. §§3601-3619) which prohibits discrimination in housing-related credit (e.g. residential mortgages, home equity lending) on the basis of race, color, religion, sex, national origin, disability, or familial status. This overlaps with ECOA on many bases. AI models used in mortgage lending or advertising of housing loans must be carefully controlled to avoid disparate impact. Notably, regulators and enforcement agencies are actively scrutinizing algorithmic bias under the FHA. In 2022, the U.S. Department of Justice filed its first case challenging **algorithmic discrimination** under the FHA, alleging that Facebook/Meta’s advertising algorithms were unlawfully excluding certain protected groups from housing ads ²⁶ ²⁷. Meta settled and agreed to overhaul its algorithms to address this bias ²⁸ ²⁹. This illustrates that the bank could face serious enforcement action if any AI it uses in housing credit or advertising results in discriminatory outcomes. To prevent this, the bank will perform robust fair lending testing on AI models and also monitor inputs – for example, ensuring that models do not use proxies for protected characteristics (such as ZIP codes that correlate with ethnicity, or behavioral data that might inadvertently favor one group). We will document our testing and, where necessary, engage third-party fair lending consultants or legal experts to review complex AI models for compliance. In addition, marketing or ad-targeting algorithms used by the bank (or its vendors) for credit offers will be reviewed to ensure they do not systematically exclude protected classes from receiving offers for credit or other financial services (a potential “digital redlining” concern). The bank aligns its practices with HUD/DOJ guidance and any relevant court precedents (such as the recognition of disparate impact liability under the FHA in **Texas Dept. of Housing v. Inclusive Communities Project**, 576 U.S. 519 (2015)). In sum, preventing algorithmic bias is a top priority, and the bank will **terminate or modify any AI system that exhibits discriminatory effects**.

Massachusetts Anti-Discrimination Law (M.G.L. c.151B): As a Massachusetts institution, the bank is also subject to Chapter 151B of the Massachusetts General Laws, which among other things makes it unlawful to discriminate in employment, credit, housing, and public accommodations on the basis of protected characteristics (including those covered by ECOA/FHA, as well as additional categories under state law like sexual orientation, gender identity, etc.) ³⁰ ³¹. Chapter 151B §4 specifically prohibits discrimination in mortgage lending and other credit transactions ³². Therefore, any AI used in lending must equally comply with state anti-discrimination standards. Moreover, for HR uses, M.G.L. c.151B and federal EEO laws (Title VII, ADA, ADEA, etc.) apply – meaning AI cannot be used to screen out job applicants in a way that disproportionately affects protected groups (race, sex, age, disability, etc.). The Massachusetts Attorney General’s April 2024 **AI Advisory** explicitly warns that existing anti-discrimination laws *fully apply* to AI and algorithmic decision-making ³³. The bank will heed this guidance: **AI systems must be designed and operated to treat similarly situated individuals consistently, and not to impose different terms or services based on protected traits**. We will provide reasonable accommodations in the hiring process if AI tools might disadvantage individuals with disabilities (for instance, if an online video interview AI scores a person poorly due to a speech impairment, the bank will offer an alternative assessment as an accommodation) ³⁴ ³⁵. The bank also understands that using a third-party vendor’s AI does *not* shield us from liability – if that tool is discriminatory, the bank can be held responsible for its use ³⁶. Accordingly, vendor AI tools will be subjected to the same scrutiny. In summary, the bank is committed to **fair and bias-free AI**, and any violations of fair lending or civil rights laws by an AI system will be treated as a serious compliance breach, with immediate remediation and reporting to the Board and regulators as appropriate.

2. Consumer Protection and UDAAP

Unfair, Deceptive or Abusive Acts or Practices (UDAAP/UDAP): The bank has a fundamental obligation to ensure its AI usage does not engage in unfair, deceptive, or abusive acts or practices. Under the Dodd-Frank Act's UDAAP provisions and the Federal Trade Commission Act's analog for UDAP, as well as Massachusetts General Laws Chapter 93A (the Massachusetts Consumer Protection Act), the bank must avoid practices that could mislead consumers or cause substantial harm. This applies fully to AI interactions and decisions. The Massachusetts Attorney General has made clear that Chapter 93A's broad prohibition on unfair or deceptive practices **"appl[ies] to this emerging [AI] technology to the same extent as...any other product or application"** ³⁷ ³³ . For example, if an AI chatbot provides financial information or advice to customers, the information must be accurate and not misleading – the bank could be liable under consumer protection law if the chatbot's responses are materially incorrect or confusing and consumers are harmed. Therefore, content delivered by AI (such as responses in a chat or automated product recommendations) should be reviewed and tested for accuracy. The bank will implement disclaimers where appropriate (e.g. notifying users that they are interacting with an AI and providing a way to reach a human representative), to ensure transparency and avoid deception by omission.

No False or Misleading AI Claims: The bank will not overstate the capabilities of its AI products. Any marketing or description of our AI (for instance, if we offer an "AI financial advisor" service) must be truthful. The FTC has recently cracked down on companies making deceptive claims about AI technologies, and has affirmed it will "vigorously enforce the law to combat unfair or deceptive practices" involving AI ² . As a bank, we are primarily regulated for consumer protection by the CFPB, FDIC, and state authorities rather than the FTC, but the principles are the same. Internally, employees are prohibited from using generative AI (like large language model tools) to draft communications that could inadvertently contain inaccuracies presented as fact. All customer-facing AI outputs should either be pre-vetted or sufficiently constrained to prevent the generation of misleading content.

Avoiding Unfair Outcomes: An AI-driven practice could be deemed "unfair" under UDAAP if it causes substantial consumer injury that is not reasonably avoidable or outweighed by benefits. This means we must consider and mitigate potential harms from AI decisions. For instance, an algorithm that automatically decides fee waivers or account closures should be monitored to ensure it isn't mistakenly penalizing innocent customers (false fraud positives could be unfair if not promptly corrected). Similarly, AI used in collections or servicing must not harass or target vulnerable customers in a way that violates debt collection or consumer protection rules. The bank will conduct **customer impact analysis** for AI projects – asking whether the outcome could be considered unscrupulous or unsupportable if a regulator or customer examined it. We will also monitor for **customer complaints** specifically related to AI decisions or interactions as an early warning of unfair practices.

Regulatory Guidance and Enforcement Examples: We incorporate by reference relevant guidance such as the FTC's business guidance on AI (*"Aiming for Truth, Fairness, and Equity"*) and CFPB compliance bulletins on AI issues. Recent enforcement actions underscore the stakes: In Dec 2023, the FTC brought its first case alleging **algorithmic bias as an unfair practice** under Section 5 of the FTC Act ³⁸ . In that case, a company's AI-based system (facial recognition in retail security) was alleged to have caused harm through misidentifications and biased outcomes without proper safeguards ³⁹ ⁴⁰ . The consent order not only banned certain AI uses but also required the company to implement comprehensive safeguards ⁴¹ ⁴⁰ . While that case (FTC v. Rite Aid) involved retail and falls under FTC jurisdiction, the principles apply to banks via our UDAP/UDAAP obligations: failing to test an AI for accuracy or bias, and thus causing consumer harm

(like false fraud accusations or privacy intrusions), can be deemed an unfair practice ³⁹ ⁴⁰. The Massachusetts AG's April 2024 Advisory likewise flags AI risks including bias and lack of transparency, indicating that AI that does not meet "minimum quality and efficacy standards" could violate consumer protection laws ⁶. **Accordingly, this Policy mandates robust testing and quality control for AI** (to meet basic standards of accuracy and reliability), and oversight to ensure AI decisions are explainable to consumers where required, and corrected when errors are detected. If an AI tool were to produce an error that harms a consumer (for example, wrongfully denying access to funds), the bank will have procedures to promptly remediate the harm (correct the error, refund fees, etc.) and report the incident to Compliance and the AI Oversight Committee for root-cause analysis and prevention.

3. Data Privacy and Security

Gramm-Leach-Bliley Act (GLBA) – Privacy and Safeguards: The bank will handle all personal information used in AI systems in accordance with GLBA and implementing regulations. Under GLBA, the bank is required to protect the security and confidentiality of customer nonpublic personal information and to guard against anticipated threats or unauthorized access that could result in substantial harm or inconvenience to customers ⁴². This obligation extends to any AI system processing customer data. **Data Security:** All AI applications must comply with the bank's Information Security Program and the Massachusetts data security regulations (201 CMR 17.00) which set standards for safeguarding personal information of Massachusetts residents ⁴³. For example, if an AI model uses sensitive customer data (account numbers, Social Security numbers, financial transactions), that data must be encrypted in transit and at rest as required by 201 CMR 17.04, and access must be restricted to authorized personnel only. The bank will include AI systems in its cybersecurity risk assessments – recognizing that AI tools can introduce new vulnerabilities (e.g. exposure of training data, adversarial attacks manipulating model inputs, or the model outputting sensitive data). Any AI system integrated with bank data will undergo security review by IT and InfoSec, including penetration testing if applicable, to ensure it doesn't create a backdoor to customer information. We will maintain audit logs for AI data access and usage.

Privacy Notices and Limitations on Data Use: The bank's use of customer data in AI must be consistent with our privacy notices and applicable law. GLBA requires providing customers with notices about how their information is used and, in some cases, opt-out rights for data sharing with third parties. Internally, we will use customer data for AI analytics only under permissible purposes (e.g. to improve services or detect fraud, which are generally consistent with providing financial services to the customer). We will not use or share data in ways that violate privacy promises. For instance, if our privacy notice says we do not share certain information with non-affiliates except for limited purposes, we will not feed that data into an external AI vendor's system unless covered by an exception and proper contractual safeguards. We also adhere to the Massachusetts data breach law (M.G.L. c.93H): if any AI system experiences a security breach that involves personal information, the incident response and customer notification requirements of c.93H and 201 CMR 17.00 will be triggered. This means the bank must promptly notify affected Massachusetts residents and the MA Attorney General's Office, among others, if AI-related processing leads to a data breach of personal information (like unauthorized acquisition of a name combined with SSN, account number, etc.) ⁴³. Prevention is paramount – hence our vendor contracts (see below) will stipulate security standards and breach notification duties for AI providers.

Customer Confidentiality and Ethical Data Use: Even aside from legal technicalities, the bank will uphold customers' reasonable expectations of privacy. We will minimize the data fed into AI models to what is necessary for the task (data minimization principle) to reduce risk. If we use AI to analyze customer

behavior for marketing, we will avoid using sensitive attributes or intrusive data without clear customer consent. For example, we will **not** use AI to infer protected characteristics or health conditions from data in a manner that invades privacy or could be used in decisioning, unless allowed and absolutely necessary (and even then, with legal review). Any **profiling** of customers with AI (such as segmenting customers by profitability or risk) must be vetted to ensure compliance with Fair Credit Reporting Act if it constitutes a consumer report (see below) and not done in a secretly detrimental way. The bank's **Privacy Officer** or Data Protection Officer (DPO) will review AI initiatives for privacy compliance and integrate them into the bank's overall privacy program.

4. Credit Reporting and FCRA Compliance

AI systems often rely on or generate data that could fall under the **Fair Credit Reporting Act (FCRA)** if used to make credit or employment decisions. The bank will ensure that its AI usage complies with FCRA in two primary ways:

Use of Consumer Reports and Credit Information: If an AI model uses information from consumer reporting agencies (CRAs) – such as credit bureau data, credit scores, or third-party data aggregators – the bank will observe all FCRA requirements. This includes only obtaining such data for permissible purposes (e.g. in connection with a credit application, account review, fraud prevention, or as otherwise allowed by FCRA). We will provide any required notices to consumers if adverse action is taken based on information from a consumer report (for example, if an AI-driven underwriting model declines an application based on credit report data, the adverse action notice will include the credit bureau information and the consumer's rights under FCRA). Additionally, if the AI uses a credit score in taking adverse action on a consumer loan, we will disclose that credit score and related information to the consumer as required by FCRA (15 U.S.C. §1681g). The **accuracy of data** is a core FCRA principle – “consumer reporting agencies have a grave responsibility to ensure accuracy and fairness” ⁴⁴ ⁴⁵. Therefore, any AI tool that compiles or uses consumer data will be checked for accuracy. If our AI identifies a potential fraud or credit risk based on data that could be erroneous (say, a wrong criminal record or a mismerged credit file), we have processes for consumers to dispute or correct that information, consistent with FCRA dispute resolution procedures.

AI as a Consumer Reporting Agency or Score Provider: The bank will also guard against inadvertently acting as a consumer reporting agency through AI. If we develop an AI algorithm that provides customer risk scores or behavioral scores and share those with third parties for eligibility decisions, we might be deemed a CRA under FCRA. The bank currently does not intend to operate as a CRA; any such strategy would require a separate legal review and compliance program (ensuring we meet FCRA's extensive requirements for CRAs). Similarly, when using third-party AI services that provide scores or reports on consumers (e.g. an AI-driven fraud score from a vendor, or an employment background check AI tool), we will evaluate whether that vendor is a CRA and if so, ensure FCRA compliance (such as obtaining proper certifications from the vendor and providing the requisite notices to consumers). For instance, an AI-based tenant or employment screening tool must comply with FCRA's notice and adverse action processes in employment decisions; our HR department will only use such tools if the vendor contractually assures FCRA compliance and we integrate the proper pre-adverse and adverse action notification steps.

Adverse Action and Communication: Under both FCRA and ECOA, when adverse action is taken, consumers have the right to understand why. We addressed above the requirement for specific reasons under ECOA – these reasons also often overlap with FCRA obligations (for example, if based on a credit report). The bank will provide a clear explanation of adverse decisions in plain language. We acknowledge

the CFPB's warning that merely listing high-level factors without specifics is insufficient ⁴⁶ ⁴⁷ . Our adverse action notices will be periodically reviewed (with Compliance and legal input) to ensure they accurately reflect AI model outputs in a compliant manner. Where an AI model provides a probability or score, we will map that to the most appropriate reason codes or explanatory factors, rather than simply saying "score did not meet cutoff." If an AI uses non-traditional data (like transaction behaviors), the reason given will reflect that (as in CFPB's example: detail the specific behavior such as overdrafts, rather than a generic "banking history" label) ²⁵ .

In summary, the bank's AI activities will uphold the FCRA's mission of **fair and accurate credit reporting** and respect consumers' rights to privacy and explanation ⁴⁸ ⁴⁴ . Any employee or unit using consumer information for AI must coordinate with the Compliance Department to ensure all technical FCRA steps (e.g. adverse action, risk-based pricing notices, file disclosures if required) are properly executed.

5. Other Legal and Regulatory Considerations

The bank will also ensure AI compliance with the following, as applicable:

- **Bank Secrecy Act / Anti-Money Laundering (BSA/AML):** AI tools used for transaction monitoring or sanctions screening must align with FinCEN and banking regulator expectations for an effective BSA/AML program. While AI may enhance detection of suspicious patterns, the bank remains responsible for filing timely and accurate Suspicious Activity Reports (SARs) and complying with all BSA recordkeeping requirements. We will not rely on an AI system as a substitute for the required judgment of AML compliance staff – rather, it is a tool to augment their capabilities. Models used in AML will be subject to model validation and periodic tuning to minimize false negatives (missed suspicious activities) and manageable false positives. The system will be evaluated for how it prioritizes alerts to ensure it does not inadvertently de-prioritize high-risk cases due to bias in the algorithm. All use of AI in this domain will be coordinated with the BSA Officer. If any conflict arises between an AI's output and a compliance obligation (e.g. AI doesn't flag something that common sense or manual rules would consider suspicious), the bank will err on the side of compliance and investigate or report as needed.
- **ADA – Accessibility of Services:** If the bank deploys AI in customer-facing services (like a chatbot or an online decision tool), we must ensure it is accessible to people with disabilities, or alternative options are provided. Title III of the ADA (public accommodation) and relevant state laws require that our services (including digital services) be accessible. Therefore, AI-based interfaces will be tested for compatibility with assistive technologies (screen readers, etc.), and accommodations will be offered (for example, a phone line or branch assistance if someone cannot interact with the AI). Similarly, internal AI tools must be accessible to employees with disabilities per ADA Title I.
- **Records Retention and Auditability:** AI-generated decisions and communications may be subject to regulatory record-retention requirements. For example, credit decisions and the data used to arrive at them should be retained for the timeframes required by Reg B (25 months for ECOA adverse action files) and other relevant rules. The bank's record retention schedule will be updated to ensure AI-related records (including model output files, logs of chatbot conversations that relate to a complaint or a decision, etc.) are preserved as needed for examinations, audits, or litigation holds.

- **Litigation Preparedness:** The evidentiary nature of this Policy (citing laws and guidance) is intentional – the bank is preparing to defend its AI usage as responsible and compliant. We acknowledge that novel AI uses could invite lawsuits (e.g. class actions alleging discrimination or unfair practices). By adhering to this Policy, the bank positions itself to demonstrate good-faith efforts at risk management and compliance. We document our compliance steps (like bias testing results, validation reports, customer notifications) so that we have an evidence trail to show regulators or courts if ever challenged. This Policy and its implementation will be reviewed by counsel periodically to incorporate any new legal developments (such as new state AI laws or relevant court decisions).

Third-Party AI Vendor Management

When the bank relies on third-party providers for AI technologies or data, it will rigorously manage those relationships in accordance with interagency third-party risk management guidance ⁴⁹. The use of vendors **does not diminish the bank's responsibility** for compliance and performance ⁴⁹. In other words, the bank remains accountable for ensuring that outsourced AI services operate in a safe and sound manner and in compliance with all laws and regulations ⁴⁹. Key requirements for third-party AI vendor management include:

Due Diligence: Prior to entering or renewing any contract with an AI vendor (e.g. a fintech providing an underwriting model, a cloud service with machine learning analytics, or a recruitment AI tool), the bank will conduct thorough due diligence. This will evaluate the vendor's expertise, reputation, financial condition, security controls, business continuity, and compliance posture. Specific to AI, due diligence will assess the vendor's model development and validation process (do they have a robust methodology for avoiding bias and errors?), the quality and source of their training data, and their willingness to provide transparency into their models. If a vendor considers its AI model proprietary and will not disclose at least the necessary information for us to assess risk (such as how it was tested for fairness, or at least an explainability interface for results), that will be a significant red flag. The due diligence should also examine whether any regulatory actions or public controversies have involved the vendor's AI (for instance, if their tool was implicated in an FTC or CFPB enforcement for bias or if another client faced issues due to that AI). The bank will favor vendors who adhere to industry best practices (e.g. the NIST AI Risk Management Framework or similar ethical AI guidelines).

Contractual Safeguards: Contracts with AI vendors must include stringent provisions to protect the bank and its customers. At minimum, contracts will require the vendor to: (a) **Comply with all applicable laws and regulations** (e.g. nondiscrimination, data privacy, data security) in connection with providing the service; (b) Implement and maintain appropriate **information security measures** to protect any customer data shared, meeting or exceeding the requirements of our own policies and 201 CMR 17.00; (c) Notify the bank promptly of any **data breach or security incident** involving the bank's data or the AI service; (d) Provide **cooperation and transparency** to enable the bank to fulfill its compliance obligations – for example, providing sufficient detail about how the AI makes decisions to allow us to generate ECOA adverse action reasons, or allowing the bank to conduct an independent validation or audit of the model outputs (perhaps under NDA to protect intellectual property); (e) Agree to **monitoring and audit rights**, i.e. the bank (and its regulators) can audit the vendor's performance and controls as related to the service ⁴⁹; (f) Address **data ownership and usage** – data the bank provides or that is generated from our use should not be used by the vendor for other purposes beyond the scope of the contract without permission (to prevent, for instance, a vendor from repurposing our customer data to train models for other clients in a way that

we can't control, unless appropriately anonymized and permitted by privacy law); (g) Include indemnification and termination clauses – the vendor should indemnify the bank for losses arising from the vendor's failure to meet legal requirements (e.g. if their algorithm causes a regulatory violation or lawsuit due to bias, they should bear some responsibility), and the bank should have the right to terminate the relationship if the vendor's AI is found non-compliant or high-risk.

Ongoing Monitoring of Third Parties: Managing third-party AI risk is not a one-time effort at onboarding – it requires continuous oversight. The responsible department (with Vendor Management and the AI Oversight Committee) will establish performance metrics and review frequency for each AI vendor. For example, if using a third-party fraud detection AI, we will monitor its alert precision and any missed incidents, and hold regular service meetings to discuss improvements. If the AI vendor updates their model, we must be notified and possibly have the right to approve significant changes before they affect us. We will also track any emerging regulatory guidance or enforcement that might implicate our vendor – e.g. if the CFPB or FTC issues a warning about a practice that our vendor's AI does, we will address it immediately with the vendor. **Third-Party Risk Lifecycle:** The bank will follow the stages outlined in regulatory guidance – planning, due diligence, contract negotiation, ongoing monitoring, and contingency planning ⁵⁰ ⁵¹. Particularly, contingency planning means we should have a plan if the vendor fails or if we must quickly halt using their AI (for compliance reasons or poor results). For critical AI services, we will identify alternatives or manual workarounds to ensure continuity.

The Board and management understand that regulatory agencies (FDIC, OCC, Federal Reserve) expect robust third-party oversight. The **Interagency Guidance on Third-Party Relationships (2023)** and the **Community Bank Third-Party Risk Management Guide (2024)** emphasize that while third parties can provide access to innovative tech like AI, banks must properly manage the associated risks and cannot outsource responsibility ⁵² ⁴⁹. This Policy incorporates those expectations by reference. The bank will also report significant third-party AI engagements to regulators in supervisory discussions as appropriate, especially if the AI is performing functions core to safety and soundness or consumer protection.

Monitoring, Audit, and Reporting

Continuous Monitoring of AI Outcomes: After deployment, every AI application will be subject to continuous monitoring as earlier described. Results of this monitoring shall be reported to relevant oversight bodies. For instance, the Compliance Department will receive periodic reports on any consumer harm incidents or complaints involving AI (e.g. number of adverse action notices challenged by customers, or any detected instances of bias). The Model Risk Management function will track model performance metrics and provide a **Model Risk Dashboard** to the AI Oversight Committee quarterly, highlighting any AI models with deteriorating performance or high risk indicators. Any **exceptions or policy violations** (e.g. a model that was launched without proper approval, or a control finding that validation was missed by its due date) must be logged and promptly remediated. The AI Oversight Committee will escalate material issues to senior management and the Board Risk Committee. For example, if monitoring reveals that an AI credit model may be exhibiting disparate impact against a protected group, this is a material finding – the Committee will inform the Board and potentially pause that model's use until resolved.

Internal Audit: The Internal Audit department shall, on a risk-based cycle, audit the AI governance process and controls. At least annually, Internal Audit will review a sample of AI systems (or all high-risk AI systems) to test compliance with this Policy and related procedures. This includes verifying that required approvals were obtained, validations performed, and ongoing monitoring evidence is maintained. Audit will also

evaluate whether regulatory requirements are being met (e.g. check a sample of adverse action notices for AI-driven denials to ensure reasons are specific and compliant). Findings from audit will be reported to the Audit Committee of the Board and tracked to resolution by management.

Regulatory Examinations: The bank will facilitate open examination of its AI models and governance by its regulators (FDIC, Massachusetts Division of Banks, Federal Reserve, OCC – as applicable to our charter and affiliates). Examiners will be provided access to model documentation, validation reports, and governance records to demonstrate our compliance. We note that regulators are actively monitoring AI developments – for example, the GAO reported in 2025 that regulators are assessing AI risks and may update guidance as needed ⁵³. The bank will stay informed of evolving supervisory expectations (such as any new guidance on AI model governance or algorithmic bias from federal banking agencies, CFPB, or the Massachusetts DOB) and adjust this Policy accordingly. Any **regulatory findings or matters requiring attention (MRAs)** related to AI will be given high priority for prompt correction.

Board Reporting: Management will provide the Board (or relevant Board committee) with at least an annual **AI Risk Management Report**. This report will summarize the inventory of AI systems in use, the benefits realized, and the risk profile (including any incidents, validation results, and remediation actions over the period). It will also update the Board on regulatory developments around AI. Given the fast-moving nature of AI, the Board has directed management to be proactive – the Board does not want the bank to be a “poster child” for AI gone wrong ⁵⁴ ⁵⁵. Rather, by having strong oversight, we aim to be seen as a prudent adopter that regulators can use as a model for industry best practices.

Policy Review and Updates: This Policy shall be reviewed at least annually, and earlier if needed to incorporate new laws, regulations, or guidance. Any changes will be approved by the Board. The Policy may also be reviewed by external experts or counsel periodically to ensure it remains comprehensive and up-to-date. The formal governance structure (Board-approved policy and management oversight) will serve as evidence of the bank’s commitment to responsible AI use, which is critical in examinations and any potential investigations.

Training and Awareness

The bank will conduct training for all relevant personnel on this AI Usage Policy and their responsibilities. This includes: front-line staff who use AI tools (so they understand the tool’s proper use and limits), model developers and data scientists (on compliance and ethical considerations), risk and compliance teams (on techniques for AI oversight), and senior management/Board (on strategic and oversight aspects of AI). A training module on **AI Ethics and Compliance** will be incorporated into the annual compliance training curriculum for employees, emphasizing issues like avoiding bias, recognizing potential AI pitfalls (e.g. over-reliance on automated results), and the importance of human oversight. Employees are encouraged to raise concerns if they suspect an AI system is not functioning as intended or may be causing unfair outcomes. Whistleblower protections apply equally to reports of AI-related misconduct or risks.

Additionally, the bank will keep abreast of industry best practices by participating in forums, webinars, or regulator-sponsored discussions on AI in financial services. Learnings from these forums will be shared internally. We will also provide guidance to employees on the **acceptable use of AI** in their day-to-day work (e.g. using ChatGPT-like tools for drafting code or documents) to ensure data is not inadvertently exposed and outputs are verified – this may be covered in an IT or info-security policy but is acknowledged here due

to its relevance. Overall, fostering a knowledgeable workforce will help ensure that from the front lines to the Board room, the bank uses AI *cautiously, ethically, and in compliance with the law* ¹ .

Appendix A: Key Laws, Regulations, and Guidance Mapped to AI Usage

The following table summarizes major legal and regulatory references applicable to the bank's AI use, and how they inform this Policy:

Law / Guidance	Applicability to AI Use	Policy Integration
Mass. Gen. Laws c. 93A (Consumer Protection Act) – Prohibits unfair or deceptive acts in trade or commerce. ¹²	All customer-facing AI interactions and outcomes (chatbots, product recommendations, etc.) must not mislead or harm consumers. Chapter 93A's broad mandate evolves with the times to cover AI-related practices ⁶ .	Policy requires AI outputs to be accurate and transparent; testing and oversight prevent deceptive results. We cite AG's advisory that AI is subject to c.93A to ensure compliance ¹² .
Mass. Gen. Laws c. 93H & 201 CMR 17.00 (Data Security Law & Reg.) – Requires safeguarding personal information of MA residents and breach notification ⁴³ .	Any AI system handling personal data (customer or employee) must implement required security controls (encryption, access limits) and follow breach protocols.	Policy mandates InfoSec review of AI, compliance with encryption standards, vendor breach clauses, and incident response alignment with 93H. Citations to AG advisory reinforce these duties ⁴³ .
Mass. Gen. Laws c.151B (Anti-Discrimination) – Prohibits discrimination in credit, employment, etc., on protected bases ³⁰ ⁵⁶ .	AI used in lending or hiring must not result in disparate treatment or impact against protected classes (state and federal categories). State law parallels ECOA, FHA, ADA, etc., extending to sexual orientation, gender identity, and more.	Policy requires bias testing and fairness controls for all AI. It references the AG's guidance confirming c.151B applies to AI ³³ and includes procedures (e.g. HR review of hiring AI, fair lending analysis of credit AI) to prevent violations.
Equal Credit Opportunity Act (ECOA) & Reg. B (15 U.S.C. 1691; 12 C.F.R. 1002) – Fair lending in credit decisions ⁸ .	AI in credit underwriting, pricing, or marketing must not discriminate (protected traits) and must produce specific reasons for adverse actions ⁷ .	Policy imposes fair lending testing on AI models and requires explainability. Cites CFPB guidance that "no special exemption" for AI in adverse action duties ²¹ . AI credit decisions are subject to human oversight until proven compliant.

Law / Guidance	Applicability to AI Use	Policy Integration
Fair Housing Act (FHA) (42 U.S.C. 3601-3619) – Fair lending in housing-related credit ²⁶ .	AI affecting residential mortgage or housing loan decisions/ advertising must not discriminate (race, color, religion, sex, disability, familial status, national origin). Disparate impact liability is recognized.	Policy includes specific fair lending review for mortgage AI. References DOJ's first algorithmic bias case under FHA (Meta settlement) to underscore enforcement risk ²⁷ ²⁸ . AI advertising tools are reviewed for compliance.
Gramm-Leach-Bliley Act (GLBA) – Privacy Rule & Safeguards Rule (15 U.S.C. 6801 et seq.) ⁴² .	Governs how customer personal financial information is collected, used, and protected. AI that uses customer data must comply with GLBA privacy notices and protect data confidentiality, integrity, and security ⁴² .	Policy mandates data minimization for AI, adherence to privacy notices, and strong security controls. Cites GLBA's requirements to secure customer records ⁴² . Vendor agreements address GLBA obligations (confidentiality clauses, etc.).
Fair Credit Reporting Act (FCRA) (15 U.S.C. 1681 et seq.) – governs consumer reports and data fairness ⁴⁸ ⁴⁴ .	AI using credit bureau data or making eligibility decisions must ensure accuracy, permissible use, and proper adverse action notice. If AI produces consumer report-like outputs, FCRA may apply.	Policy ensures FCRA compliance: permissible purpose for data, disclosures, adverse action notices with credit score info if used. Cites FCRA's purpose of fair, accurate reporting ⁴⁴ . AI vendors acting as CRAs are assessed and required to comply.
Bank Secrecy Act (BSA) and AML Regulations (31 U.S.C. 5311; 12 C.F.R. 21.21, etc.).	AI in transaction monitoring or sanctions screening must meet regulatory standards for detecting and reporting suspicious activity.	Policy integrates AI into BSA program with validation to avoid missed SARs. Stresses no relaxation of standards due to AI. While no specific citation (BSA/ AML expectations are well-known), the Policy commits to maintaining effective AML compliance whether manual or AI-assisted.
FTC Act (Section 5) & Dodd-Frank UDAAP (15 U.S.C. 45; 12 U.S.C. 5531) – Unfair or deceptive acts/ practices ² .	Although banks aren't directly regulated by FTC, analogous standards via CFPB/FDIC apply. AI must not commit unfair or deceptive acts (e.g. hidden biases causing harm, or misleading AI marketing).	Policy's UDAAP section addresses this, citing FTC and CFPB stances. For example, FTC Chair's quote " <i>no AI exemption</i> " to consumer protection laws ² is included to reinforce zero tolerance for AI-enabled fraud or deception.

Law / Guidance	Applicability to AI Use	Policy Integration
Interagency Model Risk Management Guidance (OCC 2011-12; FRB SR 11-7) ⁵ .	Outlines regulators' expectations for model governance, validation, and oversight for all models, explicitly including AI/ML models.	Policy's governance framework is built on this guidance – requiring robust model development, independent validation, ongoing monitoring, etc. ⁵ . We document how each AI model complies with these principles.
Interagency Third-Party Risk Management Guidance (FIL-29-2023; OCC Bulletin 2023-17) ⁴⁹ and Guide for Community Banks (2024) ⁵² .	Emphasizes that banks must manage outsourced services (including AI vendors) with the same rigor as internal processes. The bank retains responsibility for compliance and customer protection even when using third-party AI ⁴⁹ .	Policy's vendor management section aligns with this guidance: conducting due diligence, strong contracts, ongoing monitoring. Cites the guidance that third-party use doesn't remove the bank's accountability ⁴⁹ .
Mass. AG AI Advisory (2024) ¹² ⁶ – Advisory on existing laws applying to AI.	Clarifies that Massachusetts laws (93A, 93H, 151B, etc.) fully apply to AI developers, sellers, and users. Highlights risks like bias, lack of transparency.	Policy is informed by this advisory throughout (noted in multiple sections). It explicitly references the AG's position that AI must meet minimum standards and existing laws ⁶ , reinforcing our compliance stance.
Federal Agency Guidance & Statements on AI Bias – e.g. Joint CFPB/FTC/DOJ/ EEOC Statement on AI (Apr 2023) ¹⁹ ² .	Signals unified enforcement approach against biased or harmful AI. Warns companies to uphold fairness, justice, and equal opportunity in use of automated systems.	Policy cites the joint statement to underline that multiple regulators are watching AI for civil rights and consumer protection issues ¹⁹ . This supports our strict approach to preventing discrimination and unfair practices via AI.
Enforcement Actions & Cases – e.g. CFPB Guidance on AI Credit Denials ⁷ ; DOJ v. Meta (2022) ²⁶ ; FTC v. Rite Aid (2023) ⁴⁰ .	Real-world examples of AI-related legal violations and resolutions, illustrating consequences of non-compliance (fines, business changes, bans).	These are woven into Policy narrative to provide cautionary tales (e.g. Meta case for FHA, Rite Aid for unfair practices). They serve to educate stakeholders on why the Policy's requirements matter (to avoid those outcomes).

Note: This Appendix is not exhaustive of all potentially applicable authority. The bank will monitor and incorporate new laws (such as any future federal AI regulations or state laws) and regulatory guidance (e.g. OCC/CFPB bulletins or court decisions) as they emerge. The citations **[]** above refer to sources that provide context or mandates influencing this Policy.

Appendix B: AI Risk Assessment Checklist (Sample)

(This checklist is used by the AI Risk Review Committee during pre-implementation assessment of any new AI system. It is included here for reference and may be updated by the Committee as needed.)

1. **Use Case Description:** Has the business unit clearly described the AI system's purpose, scope, and how it will be used? Identify whether it is customer-facing or back-office, and the criticality of the function.
2. **Data Inputs:** What data will the AI use? List data sources and types (customer personal data, transaction data, credit bureau data, etc.). **Privacy review:** Is use of this data permitted under privacy policies and law? ⁴³ Are we minimizing personal data usage?
3. **Model Type and Technology:** Briefly describe the AI model (e.g. random forest, neural network, large language model). Is it a third-party model or developed in-house? **Transparency:** Is the model inherently interpretable? If not, what explainability tools will be used? ¹³
4. **Fairness & Bias Check:** What is the risk of bias or disparate impact? Have protected attributes or proxies been removed from inputs? **Testing:** Plan for pre-deployment bias testing – e.g. simulate outputs for different demographic groups. Will an independent fairness audit be conducted? ²⁷
5. **Regulatory Compliance:** Identify key regulations applicable (see Appendix A). For each, note compliance plan:
 6. ECOA/FHA (if lending): Fair lending test and adverse action reasons documented ⁷ .
 7. UDAP/UDAAP: Review outputs for potential consumer harm or deception ⁶ .
 8. ADA (if HR or customer service): Ensure accommodations or alternative processes exist ³⁴ .
 9. BSA/AML (if applicable): Consult BSA Officer on integration and monitoring.
10. Others as relevant.
11. **Model Risk Level:** Classify model tier (e.g. High risk if making autonomous decisions affecting customers or safety and soundness). Higher risk demands stricter validation and monitoring frequency ⁵ .
12. **Validation Plan:** Has a model validation been scheduled? Identify who will validate and expected completion date. Validation must cover conceptual soundness, outcome accuracy, and appropriate use controls ⁵ .
13. **Controls and Human Oversight:** What controls will mitigate model risk? (Examples: review thresholds where human must approve the AI's decision; limits on use until certain confidence achieved; monitoring alerts for anomalies; periodic retraining policy). If the AI fails or produces an alert, who is responsible for intervention?

14. **Vendor Assessment (if external):** Due diligence completed on vendor? Results: _____. Contract clauses included for compliance, security, audit, and performance? ⁴⁹ Is there an exit strategy if vendor service degrades or is terminated?
15. **Security Assessment:** Has InfoSec vetted the AI system and data flows? Data storage encryption confirmed? Access controls defined (who can query or modify the model)? For cloud-based AI, does it meet the bank's cloud security policy?
16. **Performance Metrics:** Define KPIs/KRIs for the AI (accuracy, error rates, false positive/negative rates, throughput, etc.). What is the acceptable range? Outline an initial monitoring plan for the first 3-6 months.
17. **Incident Response:** If the AI produces an obviously incorrect or harmful output, what is the process to catch and correct it? (E.g. customer-facing AI: customer support can intervene; credit AI: exception process for overrides). Also, if a compliance issue is discovered (like biased outcome), plan for prompt model correction or shutdown.
18. **Documentation:** Ensure documentation (model development document or vendor documentation, validation report, test results, this checklist, approval memo) is filed in the Model Inventory repository.
19. **Approval:** Based on the above, does the Committee approve proceeding? ____ Yes / No . **Any conditions on approval (e.g. limit scope, require enhancements, additional monitoring) should be listed. Senior management sign-off obtained (CRO, Compliance Officer, etc.)? .**

This checklist, once completed and signed by reviewers, is kept on record to demonstrate the bank's diligence in AI implementation, in line with regulatory expectations for proactive risk management ⁵⁴ ⁵³ .

¹ ³ ⁶ ¹² ³³ ⁴³ [mass.gov](https://www.mass.gov/doc/ago-ai-advisory-41624/download)

<https://www.mass.gov/doc/ago-ai-advisory-41624/download>

² ¹⁸ ¹⁹ FTC Chair Khan and Officials from DOJ, CFPB and EEOC Release Joint Statement on AI | Federal Trade Commission

<https://www.ftc.gov/news-events/news/press-releases/2023/04/ftc-chair-khan-officials-doj-cfpb-eoc-release-joint-statement-ai>

⁴ ⁵ ²⁴ The Fed - Supervisory Letter SR 11-7 on guidance on Model Risk Management -- April 4, 2011

<https://www.federalreserve.gov/supervisionreg/srletters/sr1107.htm>

⁷ ²¹ CFPB Issues Guidance on Credit Denials by Lenders Using Artificial Intelligence | Consumer Financial Protection Bureau

<https://www.consumerfinance.gov/about-us/newsroom/cfpb-issues-guidance-on-credit-denials-by-lenders-using-artificial-intelligence/>

⁸ ¹³ ²⁵ ⁴⁶ ⁴⁷ Interpretable Algorithms as a Potential Solution to CFPB's Guidance on AI-driven Credit Denials - Consumer Finance Insights (CFI)

<https://www.consumerfinanceinsights.com/2024/03/28/interpretable-algorithms-as-a-potential-solution-to-cfpbs-guidance-on-ai-driven-credit-denials/>

9 10 34 35 36 Algorithms, Artificial Intelligence, and Disability Discrimination in Hiring | ADA.gov
<https://www.ada.gov/resources/ai-guidance/>

11 20 Federal Regulators Approve New Rule on AI Use and Bias Risks in Real Estate Valuation – Debevoise
Data Blog
<https://www.debevoisedatablog.com/2024/07/01/federal-regulators-approve-new-rule-on-ai-use-and-bias-risks-in-real-estate-valuation/>

14 15 16 17 22 23 54 55 AI's rapid rise compels smart risk management for banks | ABA Banking
Journal
<https://bankingjournal.aba.com/2024/11/ais-rapid-rise-compels-smart-risk-management-for-banks/>

26 27 28 29 Office of Public Affairs | Justice Department Secures Groundbreaking Settlement Agreement
with Meta Platforms, Formerly Known as Facebook, to Resolve Allegations of Discriminatory Advertising |
United States Department of Justice
<https://www.justice.gov/archives/opa/pr/justice-department-secures-groundbreaking-settlement-agreement-meta-platforms-formerly-known>

30 The Massachusetts Commission Against Discrimination: Steady in ...
<https://bostonbar.org/journal/the-massachusetts-commission-against-discrimination-steady-in-the-storm/>

31 32 56 804 CMR, § 2.05 | State Regulations | LII / Legal Information Institute
<https://www.law.cornell.edu/regulations/massachusetts/804-CMR-2-05>

37 AG Campbell Issues Advisory Providing Guidance On How State Consumer Protection And Other Laws
Apply To Artificial Intelligence | Mass.gov
<https://www.mass.gov/news/ag-campbell-issues-advisory-providing-guidance-on-how-state-consumer-protection-and-other-laws-apply-to-artificial-intelligence>

38 39 40 41 FTC Signals Tough Line in First AI Discrimination Case Under Section 5 | Perkins Coie
<https://perkinscoie.com/insights/update/ftc-signals-tough-line-first-ai-discrimination-case-under-section-5>

42 15 U.S.C. § 6801 - U.S. Code Title 15. Commerce and Trade § 6801
<https://codes.findlaw.com/us/title-15-commerce-and-trade/15-usc-sect-6801/>

44 45 48 15 U.S. Code § 1681 - Congressional findings and statement of purpose | U.S. Code | US Law |
LII / Legal Information Institute
<https://www.law.cornell.edu/uscode/text/15/1681>

49 50 51 52 Third-Party Risk Management, A Guide for Community Banks | FDIC.gov
<https://www.fdic.gov/news/financial-institution-letters/2024/third-party-risk-management-guide-community-banks>

53 GAO-25-107197, ARTIFICIAL INTELLIGENCE: Use and Oversight in Financial Services
<https://www.gao.gov/assets/gao-25-107197.pdf>